BIA, RTO y RPO: decidir qué se recupera primero y con qué estrategia

Del plan a los números

En la lección anterior se diseñó un plan de recuperación: quién declara el desastre, en qué orden se levantan los sistemas y quién aprueba el retorno. El plan usaba MTPD, RTO y RPO, pero los tomaba como datos dados. Esta lección pregunta de dónde salen esos números y qué hacer cuando la organización no puede cumplirlos.

Según la planificación de la lección 14, al terminar deben poder **construir un BIA simplificado y justificar una estrategia de recuperación**. La lectura conecta el impacto al negocio con las dependencias, los objetivos, la capacidad actual y una recomendación que la gerencia pueda decidir.

> ¿Cuánto tiempo y cuántos datos podemos perder, cuánto perdemos hoy y cuánto cuesta no perderlos?

Cuatro ideas ordenan la lección:

1. **el BIA analiza procesos, no aplicaciones**: lo que se valora es el daño al negocio en el tiempo;
2. **los objetivos se derivan del impacto**: el MTPD sale de la tabla de impactos; el RTO y el RPO se fijan a partir de él y de la tolerancia de datos;
3. **un objetivo no es una capacidad**: la diferencia entre lo que se necesita y lo que se demostró es la **brecha**;
4. **la brecha se cierra con estrategia, alternativa o aceptación formal**, nunca cambiando el número para que calce.



1. Qué es un BIA

El **análisis de impacto al negocio** (BIA, *Business Impact Analysis*) responde qué le pasa a la organización si un proceso se detiene, y cómo empeora a medida que pasa el tiempo. NIST SP 800-34 lo organiza en tres pasos:

Paso	Pregunta	Resultado
1. Procesos y criticidad	¿Qué procesos importan y cuánto daño causa su interrupción?	Impacto por horizonte y MTPD
2. Recursos requeridos	¿Qué personas, sistemas, datos y proveedores necesita cada proceso?	Dependencias y recursos mínimos
3. Prioridades de recuperación	¿En qué orden y con qué objetivos se recuperan?	RTO, RPO y orden

El BIA se hace sobre **procesos de negocio** (vender, despachar, facturar), no sobre aplicaciones (ERP, servidor de correo). Una aplicación importa porque un proceso la necesita: el ERP es crítico porque sin él no se despacha.

Lo construyen juntos los **dueños de los procesos**, que conocen las consecuencias, y **TI**, que conoce las dependencias y la capacidad. Si lo hace solo TI, termina priorizando servidores.

Qué información se levanta

Antes de asignar tiempos, registren qué entrega el proceso, a quién y qué significa que vuelva a funcionar. «Recuperar despacho» puede significar emitir guías y entregar pedidos prioritarios, aunque todavía no se haya eliminado todo el atraso. Pregunten al dueño qué volumen mínimo necesita, qué fechas cambian el impacto y desde qué registros podría reconstruir información. Cada respuesta debe tener una fuente: entrevista, contrato, registro operativo o prueba.

El BIA estudia las **consecuencias de la interrupción**. Para esta actividad, no se reduce la prioridad de un proceso porque la falla parezca poco probable: primero se establece cuánto daño produciría y luego se decide cómo tratar el riesgo.

2. Categorías y escala de impacto

Para que dos personas valoren igual un mismo proceso, la organización fija **criterios explícitos** antes de valorar. Las categorías habituales son:

Categoría	Ejemplos de consecuencia
Financiera	Ventas perdidas, multas, costos extra
Clientes y reputación	Reclamos, pérdida de clientes, prensa
Operación y contratos	Atrasos, incumplimiento de SLA, término de contratos
Legal y regulatoria	Plazos legales, infracciones, sanciones
Personas	Seguridad y salud de trabajadores o clientes

Cada categoría tiene una escala de cuatro niveles (Bajo, Medio, Alto, Crítico) con umbrales concretos. Por ejemplo: «Alto = pérdida entre $ 10 y 30 M» o «Crítico = término de un contrato mayorista». Sin umbrales, «alto» significa algo distinto para cada persona.

3. El impacto crece con el tiempo

El daño de una interrupción no es fijo. Una hora sin facturar casi no se nota; un día puede significar una infracción. Por eso el BIA valora cada proceso en varios **horizontes** (por ejemplo, 2, 4, 8 y 24 horas):

Horizonte	Pérdida	Clientes	Legal	Operación	Nivel
2 h	Baja	Sin efecto	Sin efecto	Mismo turno	Bajo
8 h	Media	Reclamos aislados	Atraso subsanable	En el día	Medio
24 h	Alta	Multa contractual	**Infracción cierta**	Más de un día	**Crítico**

Dos reglas para leer la tabla:

- **Impacto dominante.** El nivel del horizonte es el más alto de sus categorías. Un proceso con pérdida baja puede ser Crítico si a esa hora se pierde un contrato o se comete una infracción.
- **Calendario.** La criticidad cambia según la fecha: cierre de mes, campaña de ventas, día de pago de remuneraciones. El BIA registra el período más exigente o declara ambos valores.

Ejemplo de lectura: si a las 8 horas las categorías son Medio, Crítico, Bajo y Alto, el nivel es **Crítico**; no se promedian. La justificación debe nombrar la consecuencia que domina: «se pierde un contrato», por ejemplo. Si a las 4 horas todavía era Alto, en este BIA simplificado se registra MTPD de 8 horas. En un análisis real habría que precisar en qué momento entre ambos horizontes se cruza el límite.

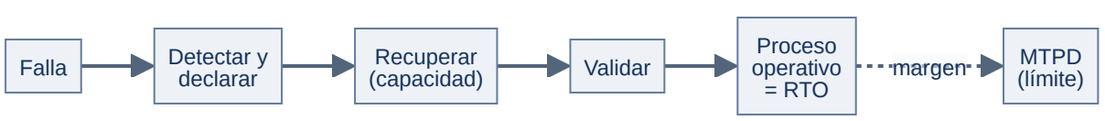
4. Del impacto a los números

MTPD

El **MTPD** (*Maximum Tolerable Period of Disruption*, período máximo tolerable de interrupción) es el tiempo tras el cual el daño se vuelve inaceptable. NIST SP 800-34 lo llama MTD (*Maximum Tolerable Downtime*); en el curso se usa MTPD, como en ISO 22301. La organización define qué nivel es inaceptable; si es Crítico, el MTPD es el primer horizonte que llega a Crítico.

RTO

El **RTO** (*Recovery Time Objective*) es el tiempo en que el proceso **debe** volver. Siempre es menor que el MTPD, porque recuperar no empieza en el minuto cero: hay que detectar el problema, decidir, declarar el desastre y, al final, validar.



Una política simple fija el margen, por ejemplo «al menos 1 hora antes del MTPD». Con MTPD de 8 horas, el RTO es de 7 horas o menos.

Ese margen es una **regla del caso**, no una cantidad universal exigida por NIST. Además, volver a operar significa alcanzar el nivel mínimo acordado con el dueño; ponerse al día con todos los pedidos pendientes puede tomar más tiempo. En cada medición se debe indicar desde cuándo se cuenta y si incluye detección, recuperación y validación, para comparar objetivo y capacidad sobre la misma base.

RPO

El **RPO** (*Recovery Point Objective*) es cuántos datos recientes se pueden perder, medido hacia atrás desde la falla. No sale del MTPD, sino de la **tolerancia de datos** del dueño: ¿qué pasa si hay que volver al estado de hace

una hora, o de ayer? ¿Se pueden reconstruir esos datos desde otra fuente?

Pregunta al dueño	Si la respuesta es...	RPO
¿Se pueden reconstruir los datos perdidos?	Sí, desde otra fuente y en poco tiempo	Más holgado (horas)
¿Cuánto cuesta reconstruirlos?	Recontar una bodega, rehacer guías	Lo que evite ese costo
¿Hay obligación legal sobre esos datos?	Documentos tributarios, fichas clínicas	Exigente (minutos)

Error común: confundir RPO o RTO con el **tiempo de retención** (cuántos días se guardan los respaldos). Retener 30 días de copias no dice nada de cuánto se tarda en restaurar ni de cuántos datos se pierden.

Ejemplo temporal: la falla ocurre a las 15:00 y el último punto recuperable corresponde a las 14:00: se pierde hasta 1 hora de datos. Si la operación validada vuelve a las 18:00, la interrupción fue de 3 horas. Son medidas distintas: recuperar rápido puede dejar datos antiguos, y conservar datos recientes no garantiza recuperar rápido.



Figura 1. En este ejemplo, el retorno a las 18:00 cumple el RTO y deja una hora antes del MTPD. El intervalo anterior a la falla representa los datos que se tolera perder.

5. Reglas de coherencia

Un BIA defendible cumple cuatro reglas:

1. **RTO < MTPD**, con el margen que fija la política.
2. **La capacidad de protección debe cumplir el RPO objetivo**: si se respalda una vez al día, la pérdida puede llegar a 24 horas. Un RPO de 1 hora exige puntos recuperables separados por no más de una hora; si hoy no existen, se declara la brecha.
3. **Una dependencia se recupera antes que su consumidor**: si la venta necesita el ERP en 3 horas, el ERP no puede tener un RTO de 7.
4. **Un recurso compartido toma el objetivo más exigente**: si el ERP sirve a tres procesos, su RTO y su RPO son los del proceso que menos tolera.

Objetivo propuesto	Problema	Corrección
MTPD 4 h, RTO 6 h	Recupera después del límite tolerable	Fijar RTO ≤ 3 h con la política del caso y medir la brecha de capacidad
RPO 0 min con respaldo diario	Imposible con esa capacidad	Mantener el objetivo validado; declarar hasta 24 h de pérdida actual y evaluar una solución sin pérdida de escrituras confirmadas
Venta RTO 3 h, ERP RTO 7 h	La venta depende del ERP	ERP disponible antes del límite de venta, dejando tiempo para los pasos posteriores

El recurso compartido toma el menor RTO y el menor RPO que necesiten sus consumidores; **pueden provenir de procesos distintos**. Si uno exige RTO de 2 horas y RPO de 4 horas, y otro RTO de 6 horas y RPO de 15 minutos, el recurso necesita RTO de 2 horas y RPO de 15 minutos, además del margen para sus consumidores.

6. Recursos mínimos y capacidad de una cadena

Cada proceso necesita un mínimo para operar, aunque sea en modo degradado: personas, sistemas, datos, proveedores y registros vitales. El BIA los lista para saber qué recuperar primero.

Por ejemplo, despachar requiere personal autorizado, acceso a pedidos y stock, emisión de guías y coordinación con el transportista. Encender el ERP no basta si nadie puede autenticarse o la integración no transmite las guías. La recuperación se valida con una operación del proceso, no solo comprobando que el servidor responde.

Cuando los recursos forman una **cadena** (identidad → base de datos → ERP → integración), se recuperan uno después del otro y sus tiempos **se suman**. La capacidad del proceso es la suma de su cadena, no el tiempo del último sistema:

```
Identidad (2 h) + ERP (7 h) + Integración (1 h) = 10 h para despachar
```



Figura 2. Las barras comienzan cuando termina la dependencia anterior. Recuperar la integración en una hora no significa recuperar el proceso completo en una hora.

Usen siempre el tiempo **comprobado** en una prueba. Un tiempo estimado se informa como estimado y se marca como pendiente de prueba.

La suma corresponde a tareas **secuenciales**. Si dos recuperaciones pueden ejecutarse en paralelo, manda la rama que termine más tarde, más los pasos posteriores. No supongan paralelismo sin personal y recursos para hacerlo. En DELTA LOGÍSTICA el escenario establece que los recursos de una misma cadena se recuperan uno después del otro.

7. Conflictos entre procesos dependientes

Aparece un conflicto cuando un proceso crítico depende de un recurso con objetivo o capacidad más lentos. Hay tres salidas legítimas:

Opción	Ejemplo	Cuándo conviene
Elevar la capacidad de la dependencia	Replicar el ERP para recuperarlo en 2 h	El impacto justifica el costo
Alternativa manual o modo degradado	Facturar desde el portal del servicio tributario sin ERP	Existe un procedimiento real y probado
Aceptar formalmente el riesgo	La dirección firma que la venta puede quedar 5 h sin stock confirmado	El costo de cerrar la brecha supera el daño esperado

Lo que no es una salida: subir el MTPD «para que calce», o declarar un RTO que nadie sabe cumplir.

Una alternativa manual necesita límites: qué operaciones permite, cuántas por hora, quién la activa y cómo se conciliará lo registrado al volver al sistema. Si permite facturar, pero no confirmar stock, solo cubre la primera

función. La aceptación del riesgo registra la consecuencia pendiente, quién la autoriza y cuándo se revisará; no demuestra que el objetivo se cumpla.

8. Objetivo frente a capacidad: la brecha

La **brecha** es la diferencia entre el objetivo (lo que el negocio necesita) y la capacidad comprobada (lo que hoy se logra).

Proceso	Objetivo	Capacidad comprobada	Brecha	Causa
Agenda	RTO 6 h	5 h (probado)	Ninguna	—
Ficha clínica	RTO 1 h	5 h (probado)	4 h	Restauración desde respaldo nocturno
Ficha clínica	RPO 15 min	24 h	23 h 45 min	Un respaldo al día

La tabla de brechas es la parte más útil del BIA para la dirección: dice dónde está el riesgo y cuánto falta. Cambiar el número del objetivo no cierra la brecha; solo la esconde.

Para calcularla, usen la misma unidad y separen tiempo de recuperación y pérdida de datos:

```
Brecha de tiempo = máximo(0, tiempo de recuperación comprobado − RTO objetivo)
Brecha de datos  = máximo(0, pérdida de datos comprobada − RPO objetivo)
```

Una mejora puede cerrar solo una de las dos. Respaldar cada hora reduce la pérdida de datos, pero si restaurar sigue tomando 5 horas frente a un RTO de 1 hora, quedan 4 horas de brecha. La diferencia que permanece tras aplicar la estrategia es la **brecha residual**.

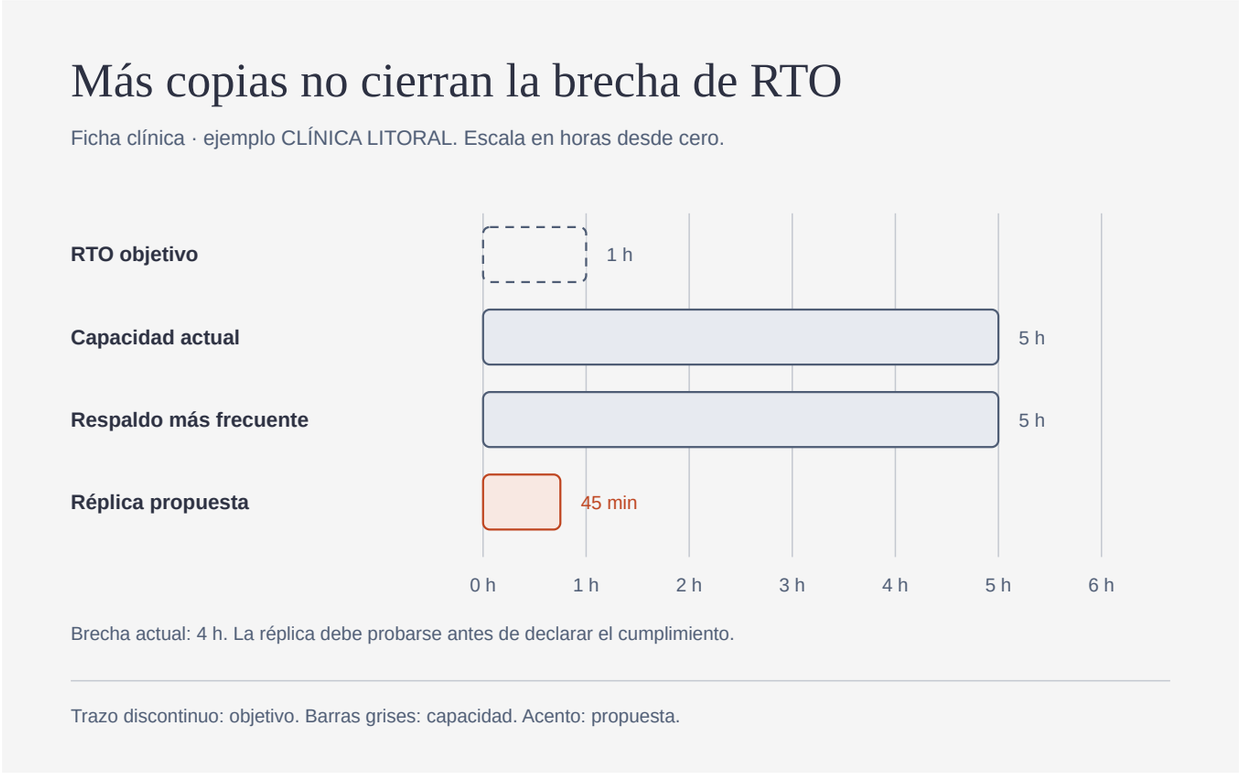


Figura 3. Ejemplo de CLÍNICA LITORAL: la frecuencia del respaldo atiende la pérdida de datos; una estrategia que acelere la recuperación debe demostrar además que cumple el RTO.

9. Estrategias de respaldo de datos

Tipo	Qué copia	Tiempo de respaldo	Tiempo de restauración
Completo	Todo	Largo	Más simple: una sola copia
Incremental	Lo cambiado desde la última copia de cualquier tipo	Corto	Más largo: la completa y todas las incrementales
Diferencial	Lo cambiado desde la última completa	Intermedio	Intermedio: la completa y la última diferencial

La **frecuencia de puntos recuperables** condiciona la pérdida de datos alcanzable: una copia utilizable cada hora permite limitarla a una hora en el escenario previsto. Una tarea programada cada hora no lo garantiza si falla o

deja copias incompletas. Pero respaldar más seguido no acelera por sí solo la restauración: el RTO depende de cuánto tarda recuperar, no de cuándo se copió.

Por ejemplo, para recuperar el jueves con una copia completa del domingo e incrementales diarios, hacen falta la completa y las incrementales del lunes al jueves. Con diferenciales diarios bastan la completa y la diferencial del jueves. La cadena necesaria debe estar disponible y ser íntegra; la prueba de restauración verifica que realmente sirve.

Para resistir incendios y *ransomware*, una copia debe estar **fuera del sitio** y **desconectada o inmutable** (no puede modificarse ni borrarse durante un período). La regla 3-2-1 lo resume: tres copias, en dos medios distintos, una fuera del sitio. Un respaldo en la misma sala y la misma red que los servidores puede perderse junto con ellos.

10. Replicación y redundancia

La **replicación** mantiene una copia viva de los datos en otro sistema:

Tipo	Cómo funciona	RPO típico	Costo y límites
Asíncrona	Envía los cambios con un pequeño retraso	Segundos a minutos	Menor costo; funciona a distancia
Síncrona	Cada escritura se confirma en ambos sitios	Casi cero	Alto costo; exige sitios cercanos y buena red

Con servidores en espera, la replicación también reduce el RTO: no hay que restaurar, solo **conmutar**.

Dos advertencias:

- **La réplica copia también los errores.** Un borrado accidental o un cifrado por *ransomware* se replican en segundos. La replicación no reemplaza al respaldo inmutable.
- **RPO cero solo es defendible con replicación síncrona probada.** Con respaldos periódicos, el RPO nunca es cero.

11. Elegir la estrategia por el objetivo y el costo

Objetivo	Estrategia típica	Costo relativo
RTO de minutos, RPO casi cero	Réplica síncrona y sitio caliente	Muy alto
RTO de 1 a 4 h, RPO de minutos	Réplica asíncrona con servidores en espera y capacidad reservada	Alto
RTO de 4 a 24 h, RPO de horas	Servidor de reemplazo y restauración desde respaldo frecuente	Medio
RTO de días	Sitio frío y restauración desde respaldo	Bajo

NIST SP 800-34 describe el equilibrio entre costo de interrupción y costo de recuperación. La decisión busca cumplir los objetivos validados con un costo justificable; el cruce de dos curvas no reemplaza el análisis del impacto ni garantiza por sí solo la mejor opción.

Además, una estrategia debe atender **la brecha del BIA**, no el último incidente. Un generador evita cortes eléctricos, pero no ayuda si se pierden los servidores.

Qué aporta un sitio alterno

Sitio	Preparación disponible	Trabajo pendiente para operar
Frío	Espacio, energía y condiciones básicas	Llevar o instalar equipos, configurar y restaurar
Tibio	Parte de los equipos y comunicaciones	Completar configuración, cargar datos y validar
Caliente	Equipos e infraestructura preparados para la recuperación	Activar, verificar datos y validar el servicio

El tipo de sitio describe su preparación; el RPO depende de cómo llegan los datos. «En la nube» tampoco define un tiempo: hay que comprobar capacidad, conectividad y acceso. Estas categorías se desarrollan en NIST SP 800-34, §3.4.3.

Comparar dentro de un presupuesto

Primero identifiquen qué brecha cubre cada opción, luego recalculen la cadena y sumen los costos del mismo período. No sumen dos veces un recurso compartido ni den por cubiertas dependencias que la oferta no incluye. Una alternativa barata que incumple el objetivo necesita declarar el riesgo restante.

Ejemplo independiente del caso: con presupuesto anual de $ 20 M, una opción de $ 12 M deja RTO de 5 h frente a un objetivo de 3 h; otra de $ 18 M logra 2 h. Si ambas cumplen el RPO y cubren las mismas

dependencias, la segunda cierra la brecha de tiempo. Ahorrar $ 6 M con la primera deja 2 h de brecha que requieren una decisión explícita.

12. Cerrar una brecha: ficha de acción

Cada brecha que se decide cerrar se convierte en una acción concreta:

Campo	Ejemplo
Brecha	Ficha clínica: RTO 5 h frente a 1 h
Estrategia	Réplica asíncrona a un servidor en otro edificio
Valor que logra	RTO 45 min, RPO 5 min
Costo	Alto
Responsable	Jefatura de TI (ejecuta); director médico (valida)
Plazo	Primer semestre
Prueba	Conmutación semestral midiendo tiempo y datos perdidos

El dueño del proceso **valida** objetivos y prioridades; TI propone, implementa y mide. Una brecha que no se cierra se declara y la **acepta formalmente** quien responde por el proceso.

La prueba debe registrar escenario, inicio y fin, último dato recuperado y una operación validada por el dueño. Si el objetivo es RTO de 1 h y RPO de 15 min, ambos deben cumplirse. Mientras la nueva solución no se pruebe, sus valores son **capacidad esperada**. NIST recomienda verificar la restauración completa y sus tiempos, considerando los componentes dependientes (SP 800-209, §4.8).

13. Ejemplo resuelto - CLÍNICA LITORAL (ficticia)

CLÍNICA LITORAL tiene tres procesos que dependen de la **identidad** y de una **base de datos clínica** compartida. El respaldo es nocturno y la restauración probada tarda 5 horas.

Impacto y MTPD

Proceso	1 h	2 h	8 h	24 h	72 h	MTPD
Ficha clínica	Alto	**Crítico** (riesgo para pacientes)	Crítico	Crítico	Crítico	2 h
Agenda en línea	Bajo	Medio	**Crítico** (pacientes sin hora, reclamos públicos)	Crítico	Crítico	8 h
Facturación a aseguradoras	Bajo	Bajo	Bajo	Medio	**Crítico** (vence el plazo de cobro)	72 h

Objetivos, capacidad y brechas

Proceso	RTO	RPO	Capacidad	Brecha
Ficha clínica	1 h	15 min (indicaciones médicas)	5 h / 24 h	**Sí, en tiempo y en datos**
Agenda en línea	6 h	4 h (las horas se reconfirman por SMS)	5 h / 24 h	En datos
Facturación	48 h	24 h	5 h / 24 h	Ninguna

Objetivo corregido: finanzas había pedido RTO de 4 horas para facturación. Con un MTPD de 72 horas no se justifica pagar por esa rapidez; se fijó en 48 horas.

Recurso compartido: la base de datos sirve a ficha y agenda, así que toma el objetivo de la ficha (RTO 1 h, RPO 15 min).

Estrategia elegida

Réplica asíncrona de la base de datos clínica a un servidor en espera en otro edificio (RTO 45 min, RPO 5 min; costo alto), más un procedimiento de ficha de urgencia en papel como modo degradado durante la conmutación. El respaldo nocturno se mantiene, con una copia inmutable fuera del sitio, porque la réplica copiaría un cifrado. La prueba: conmutación semestral, con el director médico validando el retorno.

14. Errores frecuentes

- Hacer el BIA sobre aplicaciones en lugar de procesos.

- Valorar sin criterios escritos («esto es muy crítico»).
- Mirar solo la pérdida en dinero y no la columna que domina.
- Ignorar el calendario (cierre de mes, campañas, pagos).
- Fijar un RTO igual o mayor que el MTPD.
- Pedir RPO cero con respaldos diarios.
- Confundir RTO o RPO con el tiempo de retención.
- Usar el tiempo del último sistema en vez de la suma de la cadena.
- Usar tiempos estimados como si estuvieran probados.
- Cerrar una brecha cambiando el objetivo.
- Comprar una estrategia que atiende el último incidente y no la brecha.
- Dejar brechas sin dueño, sin costo o sin prueba.

15. Glosario

Término	Definición
BIA	Análisis de impacto al negocio: consecuencias de detener un proceso en el tiempo
Horizonte	Momento en que se valora el impacto (2 h, 8 h, 24 h…)
Impacto dominante	Categoría con el nivel más alto en un horizonte
MTPD	Período máximo tolerable de interrupción
RTO	Tiempo objetivo para volver a operar
RPO	Pérdida de datos tolerable, medida hacia atrás desde la falla
Retención	Tiempo durante el que se guardan las copias de respaldo
Capacidad comprobada	Tiempo y pérdida de datos medidos en una prueba real
Brecha	Diferencia entre objetivo y capacidad comprobada
Brecha residual	Diferencia que permanece después de aplicar una estrategia
Recursos mínimos	Lo indispensable para operar en modo degradado
Respaldo incremental / diferencial	Copia de lo cambiado desde la última copia / desde la última completa
Copia inmutable	Copia que no puede modificarse ni borrarse durante un período
Replicación síncrona / asíncrona	Copia viva confirmada en cada escritura / con un pequeño retraso
Conmutación	Paso de la operación al sistema en espera
Sitio alterno	Instalación o entorno preparado para recuperar la operación si el principal no está disponible
Aceptación formal del riesgo	Decisión firmada de convivir con una brecha

Fuentes

- NIST SP 800-34 Rev. 1 - Contingency Planning Guide for Federal Information Systems. Pasos del BIA, MTD, RTO, RPO, estrategias y equilibrio de costos.
- NIST IR 8286D - Using Business Impact Analysis to Inform Risk Prioritization and Response. Impacto al negocio y su relación con el riesgo.
- NIST SP 800-209 - Security Guidelines for Storage Infrastructure. Respaldo, replicación y protección de copias.
- CISA - Guía #StopRansomware. Copias fuera de línea e inmutables ante *ransomware*.
- ISO 22301:2019 - Business continuity management systems. Marco de continuidad; la ficha pública no sustituye el estándar.